ISSP

Monday, January 18, 2021 5:40 PM

Domain 1 :- Security and Risk Management

❖ **Concepts of Confidentiality, Integrity, and Availability**

1. Confidentiality

1- Concept of the measures used to ensure the protection of the secrecy of data, objects, or resources.

1- a. Disclosure (Prevent Unauthorized access of data)

2- b. Controls :- Access Controls , Least Privileges , Need to Know)

2- Common attacks against Confidentiality: Social engineering, monitoring & eavesdropping, protocol analyzer, Espionage, Theft and Burglary

2. Integrity

1- Common attacks against Integrity: Malicious code & software, system changes, software bugs and data changes and modification

2- Alteration (Detect modification of information & Corruption)

3- Controls:- Checksum , Hashes , Digital Signature , Dual Control

4- Integrity is dependent on confidentiality. Other concepts, conditions, and aspects of integrity include the following:

5- Accuracy: Being correct and precise

6- Truthfulness: Being a true reflection of reality

7- Authenticity: Being authentic or genuine

8- Validity: Being factually or logically sound

9- Nonrepudiation: Not being able to deny having performed an

10- action or activity or being able to verify the origin of a

11- communication or event

12- Accountability: Being responsible or obligated for actions and results

13- Responsibility: Being in charge or having control over something or someone

14- Completeness: Having all needed and necessary components or parts

15- Comprehensiveness: Being complete in scope; the full inclusion of all needed elements

3. Availability

1- Destruction (Provide timely and reliable access to resources)

2- Controls :- Backups , RAID Level , Remote Site ,HA , Succession Planning ,Load Balancers.

3- availability depends on both integrity and confidentiality.

4- Without integrity and confidentiality, availability cannot be maintained. Other concepts, conditions, and aspects of availability include the following:

□ Usability: The state of being easy to use or learn or being able to be understood and controlled by a subject

□ Accessibility: The assurance that the widest range of subjects can interact with a resource regardless of their capabilities or

□ Limitations Timeliness: Being prompt, on time, within a reasonable time frame, or providing low-latency response

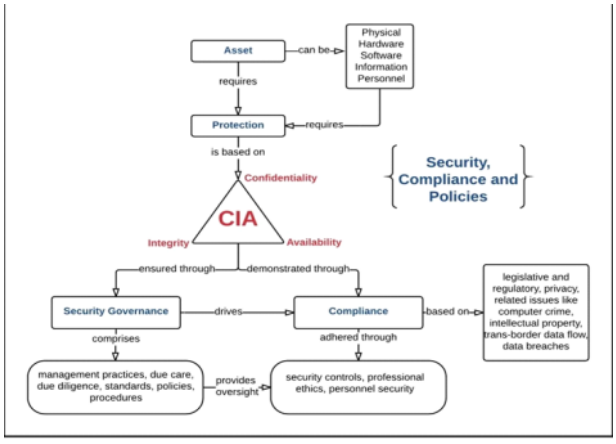
Common attacks against availability: DOS, DDOS, software flaws, physical attacks and natural disaster

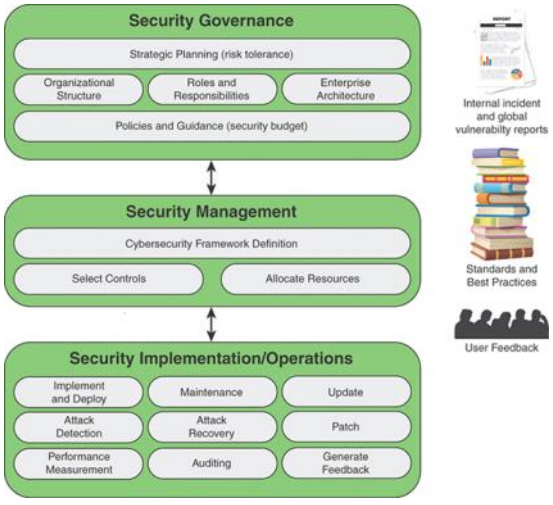
Important

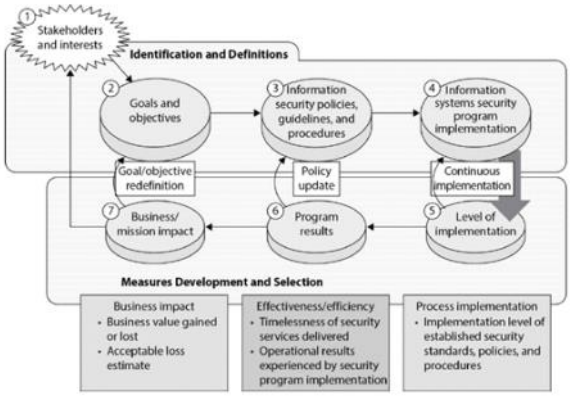
Availability:	Integrity	Confidentiality:
• Redundant array of independent disks (RAID)	• Hashing (data integrity)	• Encryption for data at rest (whole disk, database encryption)
• Clustering	• Configuration management (system integrity)	• Encryption for data in transit (IPSec, TLS, PPTP, SSH, described in
• Load balancing	• Change control (process integrity)	• Access control (physical and technical)
• Redundant data and power lines	• Access control (physical and technical)	• Encryption for data at rest (whole disk, database encryption)
• Software and data backups	• Software digital signing	• Encryption for data in transit (IPSec, TLS, PPTP, SSH,
• Disk shadowing	• Hashing (data integrity)	
• Co-location and offsite facilities	• Configuration management (system integrity)	

❖ **Organizational/Corporate Governance**

- Governance
  - Governance is the process of how an organization is managed
  - Organization has its own unique governance structure, it will also have security governance specific to its purposes and objectives
    - Enterprise Governance
      - The set of responsibilities and practices **exercised by the board and executive management** with the goal of providing strategic direction, ensuring that objectives are achieved, ascertaining that risks are managed appropriately and verifying that the organization's resources are used responsibly.
    - Strategy, Goals, Mission
      - Vision, Mission, Strategy (3-5 years) , Tactical (1-3 years) and Operations (0-6 months)
      - Risk Management is part of strategy plan, Risk assessment and analysis is part of Tactical plan (operational Plan VAPT)
      - **Security governance that does not align properly with organizational goals can lead to implementation of security policies and decisions that unnecessarily inhibit productivity, impose undue costs ,and hinder strategic intent.**







- Governance is the set of responsibilities and practices exercised by those responsible for an organization
- Include the policy, roles, and procedures the organization uses to make those decisions
- **Security governance**, is the entirety of the policies, roles, and processes the organization uses to make security decisions.
  - information security investments are appropriately directed, and the executive management has visibility into the program and is asking the appropriate questions to deter mine the effectiveness of the program
  - Provides the mechanisms for the board of directors and management to have the proper oversight to manage the risk to the enterprise to an acceptable level.
  - Ultimate Goal is to Mitigate risk to an ACCEPTABLE LEVEL
  - Security is a continues function
    1- Drive Security Governance
       a) Budget

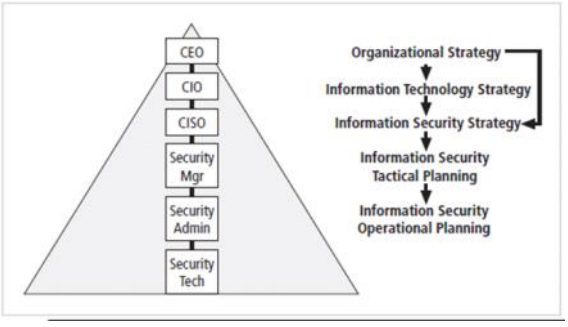
2- Roles of the information Security officer in the organization

a) Is Accountable for ensuring the protection of all the
One. business information assets from intentional & Unintentional loss , disclosure , alternative , destruction & unavailability.
b) Report as high as possible in the organization.
c) Avoid any conflict of interest.

6- Security Officer Reporting Models

- **Reporting to the CEO = Best reporting model**
- Reporting to the Information Technology (IT) Department
- Reporting to the Administrative Services Department
- Reporting to the Insurance and Risk Management Department
- Reporting to the Internal Audit Department
- Reporting to the Legal Department





7- Control Frameworks

- Consistent
- Measurable
- Standardized
- Comprehensive
- Modular

8- Control Frameworks examples

- COSO
- ISO27000
- ITIL
- COBIT

9- Due care

- The care a "reasonable person" with the same training and experience would exercise under given circumstances. An injured party cannot prove negligence. what the organization owes its customers

10- Due Diligence

- An act of management in furtherance of due care
- The actions taken to ensure that policies are being properly applied
- **Training records are an example of Due Diligence**
- any activity used to demonstrate or provide due care

Due Diligence – Before you get your license to drive a car, you are required to study to learn the rules of the road. A failure to practice this due diligence could result in you failing to pass your test. If you do pass, and do not maintain a regular knowledge of automotive laws, you may unknowingly break the law and then be

found liable regardless of your knowledge of the law.
Due Care – To keep your car running safely, you take it in for maintenance every 5-10 thousand miles. If you do not maintain your car, and it is found that a part which should have been replaced or maintained during regular maintenance caused an accident, you will be found liable because you did not practice Due Care.
LIVE EXAMPLE = before enrolling for CISSP Training it was Ur due dilligence and once you enrolled make sure you follow my guideline its your duties. Before making friends doing cyberstalking about person is due dillgence and then you become friend to carry duties with loaylity :)

❖ **Legal and Regulatory Issues that Pertain to Information Security in a Global Context**

- 1. Intellectual Property :- Protecting product of mind and ideas
  1. There is an organization called WIPO (www.wipo.int) World Intellectual Property Organization
  2. local regulations for every country. for ex: register under the regulation.

1. Type of Intellectual Property
   1. **Copyright** - It protects **expression of idea** rather than the ideas itself. Period for protection is 70 Years. Author to control how work is distributed, reproduced or used, copyright protection is weaker than patent protection, but the duration of protection is considerably longer. difficult to monitor who copies the ideas
   2. **Trademark** - Are designed to protect GOOD WILL , word , name , number , symbol , sound ,
      1. shape used to identify the product distinguish from other.
      2. TM under process (6m to 1 year) and R is registered.
   3. **Trade Secret** - Trade secrets refer to proprietary business and technical information, processes,
      1. designs, or practices that are confidential and critical to a business .Trade secrets don't require any registration.
   4. **Patent** - Patent is strongest form of intellectual property protection. Patent is strongest form
      1. of intellectual property protection. Protection of 20 years.

2. **Import & Export**

- Whenever we do export/import, we need to understand the country regulations for each country that you export/import from and to.
- The Wassenaar Agreement / arrangement - Contributes to regional and international security and stability, Promotes transparency and greater and Prevents destabilizing accumulations. International treaty signed between 48 countries last country India , dealing with Dual -use goods.
- Review the regulation when you have inter border data transfer.
- You could be breaking a country's law or an international treaty if you do not get the right type of lawyers involved
- in the beginning and follow the approved processes.
- **ITAR (International Traffic in Arms Regulations)**
  - US regulation that was built to ensure control over any export of items such as missiles, rockets, bombs, or anything else existing in the United States Munitions List (USML)
- **Regulations**
  - Regulations are mandates set by government bodies
  - List of Regulations
    - GDPR (General Data Protection Regulation) -- EU
      - Data Protection for all individual within the EU, effective May 2018.
      - Also addresses the export of personal data outside of the EU.
    - **HIPAA (Health Insurance Portability and Accountability Act) -- US**
      - **Security and Privacy of Medical Records.**
      - **Legislation that provides data privacy and security provisions for safeguarding medical information.**
      - **Covered entities are defined in the HIPAA rules as**
      - **Very Important**
      - Business Associate Agreement (BAA) is a legal contract or a written agreement that is signed between a covered entity and a Business Associate or between a Business Associate and a Business Associate Subcontractor that specifies each party's tasks to protect and secure PHI

- GLBA (Graham–Leach–Bliley Act) -- US
  - Security and Privacy of Financial Records
  - Law that requires financial institutions to explain how they share and protect their customers' private information
- SOX (Sarbanes–Oxley Act) -- US
  - Known as the "Public Company Accounting Reform and Investor Protection Act" (in the Senate) and "Corporate and Auditing Accountability, Responsibility, and Transparency Act"
- **PIPEDA Canada's (Personal Information Protection and Electronic Documents Act)**
  - **Personal Information & Protection of Electronics & Document Act - Canada**
  - **penalties up to $100,000 per violation**
- FERPA (U.S)
  - Security and Privacy of Students Educational Records
- COPPA (U.S)
  - Security and Privacy of Online collection and use of data for minors under 13 years
- PCI DSS
  - Payment Card Industry Data Security Standard
- FISMA
  - Applicable to Government Contract

4. Computer Crime

- Crime using a computer against a computer is called Computer Crime. When assessing the effect of cybercrime evaluate loss of intellectual property and sensitive data, opportunity costs, damage and brand image/reputation, penalties and compensatory payments, cost of countermeasures, cost of mitigation strategies, recovery from cyber-attacks.
- Data Breach Terminology - A data breach is when data is exfiltrated or extracted or there is a loss of control. A data breach may trigger reporting and notification requirements. As a hacker, Vector of attacks is breach, confirmed disclosure (5000 records) i.e Data Disclosure there is a security breach but no data disclosure (Breach) & there is a security breach with confirmed records disclosure (Data disclosure).
- Why Crimes are committed: you need to remember MOM stands for Motivations , Opportunities and Means If DAD do something wrong MOM will do investigation CIA - DAD - MOM - Remember

5. Privacy

- Privacy is the right of an individual to control the use of his personal information.

❖ **Professional Ethics**

- ISC2 Code of professional ethics, support organizational code of Ethics
  - The (ISC)2 member is expected to do the following:
    - **Protect society, the common good, necessary public trust and confidence, & the infrastructure.**
      i) Promote and preserve public trust and confidence in information and systems.
      ii) Promote the understanding and acceptance of prudent information security measures
      iii) Preserve and strengthen the integrity of the public infrastructure.
      iv) Discourage unsafe practice.
    - **Act honorably, honestly, justly, responsibly, and legally.**
      i) Tell the truth; make all stakeholders aware of your actions on a timely basis.
      ii) Observe all contracts and agreements, express or implied.
      iii) Treat all constituents fairly. In resolving conflicts, consider public safety and duties to principals, individuals, and the profession in that order.
      iv) Give prudent advice; avoid raising unnecessary alarm or giving unwarranted comfort.
      v) Take care to be truthful, objective, cautious, and within your competence.
      vi) When resolving differing laws in different jurisdictions, give preference to the laws of the jurisdiction in which you render your service.
    - **Provide diligent and competent service to principles.**
      i) Preserve the value of their systems, applications, and information.
      ii) Respect their trust and the privileges that they grant you.
      iii) Avoid conflicts of interest or the appearance thereof.
      iv) Render only those services for which you are fully competent and qualified.

- **Advance and protect the profession.**
  i) Take care not to injure the reputation of other professionals through malice or indifference.
  ii) Maintain your competence; keep your skills and knowledge current. Give generously of your time and knowledge in training others

❖ Security Policy, Standards, Procedures, and Guidelines

○ Policy

- Policy is important component of the information security program. Policy is the best tool by which we can comply with external regulations, directive control to control the behavior of the people. Once police documents have been created, the basis for ensuring.
- Regular review of policies provides a way to ensure that the policy continues to meet the organizational objectives and compliance requirements.
- Policy need to be review annually . New Technologies demand renew of policy
- Once policy documents have been created , the basis for the ensuring compliance is established.
- Policy is the intent / Expectations of the management. It's part of strategy.
- Approved by Senior Management (Influence ,Behaviors ,Except). **First Create Policy = > Standard=>Procedure**
- **Policy Scope**
  - □ **Purpose**
  - □ **Related document**
  - □ **Cancellation**
  - □ **Background**
  - □ **Scope**
  - □ **Policy statement**
  - □ **Responsibility**
  - □ **Ownership**

○ **Standard** (WHAT)-

- Standards serve as specifications for the implementation of policy and dictate mandatory requirements requirement , What is required
- A standard describes the specific use of technology, often applied to hardware and software.
  "All employees will receive an ACME Nexus-6 laptop with 8 GB of memory, a 3.3 GHZ quad core central processing unit (CPU), and 500-gigabyte
  disk" is an example of a hardware standard. "The laptops will run Windows 10 Enterprise, 64-bit version" is an example of a software (operating system) standard
  Standards are mandatory. Not only do they lower the TCO of a safeguard, but they also support disaster recovery.

○ **Guidelines**

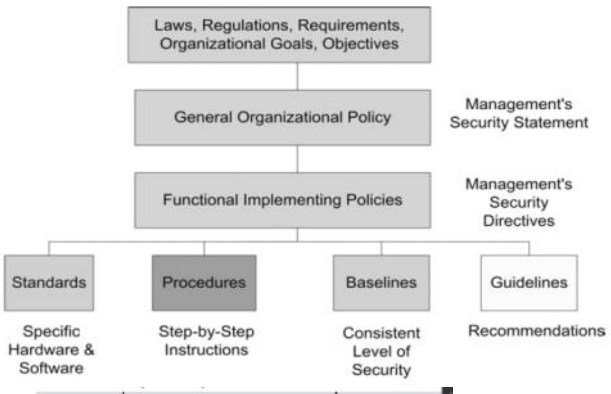
Guidelines are discretionary recommendations. A guideline can be a useful piece of advice, such as "To create a strong password, take the first letter of every word in a sentence, and mix in some numbers and symbols. 'I will pass the CISSP® exam in six months!' becomes 'Iwptcei6m!'"

○ **Baseline**

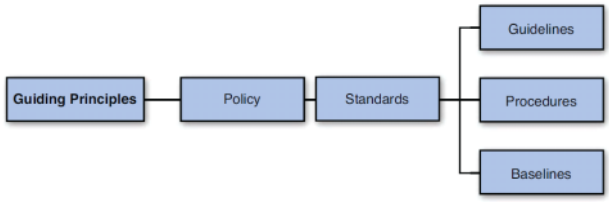
- Baselines are uniform ways of implementing a standard
- "Harden the system by applying the Center for Internet Security Linux benchmarks"
  It is acceptable to harden the system without following the aforementioned benchmarks, as long as it is at least as secure as a system hardened using the benchmarks. Formal exceptions to baselines will require senior management sign-off

`Types of Policy

- **Corporate Policy - Across the organization**
- **System Specific policy - Password Policy , Data Classification.**
- **Issue Specific Policy - in order the meet specific requirement.**



Document	Example	Mandatory or Discretionary?
Policy	Protect the CIA of PII by hardening the operating system	Mandatory
Procedure	Step 1: Install prehardened OS image. Step 2: Download patches from update server. Step 3: …	Mandatory
Standard	Use Nexus-6 laptop hardware	Mandatory
Guideline	Patch installation may be automated via the use of an installer script	Discretionary
Baselines	Use the CIS Security Benchmarks Windows Benchmark	Discretionary



❖ **Risk Management Concepts**

1. Risk
   - The Probability (Likelihood) that a given threat (Any Action) source will exercise a particular vulnerability and the resulting impact should occurs.
   - **RISK = LIKELIHOOD (Probability) * IMPACT**.
   - Information security risk management of managing the risks that's acceptable to a level accepted by the organization.
   - Owner is the one who value the asset, impose controls/safeguard and countermeasure, reduce the risk.
2. Risk Management Concepts
   - Threat- action that compromises the security by exploiting the vulnerability.
   - Threat agent - the one who carries out the attack.
   - Vulnerability - absence of safeguard (Preventive/proactive control) / counter measure (reactive after failure of the safeguard ex: Incident management team)
   - Likelihood: Change of occurring.= Control introduce to reduce likelihood
   - Impact: what's the impact of.
   - Residual Risk: Risk after implementing he controls is residual risk
3. Managing Security Risks
   - The purpose of security is to reduce the possibility of a risk becoming a reality.
   - Risk: The possibility of unwanted damage occurring
   - Risk Management: Identifying, assessing, and reducing risk to an acceptable level
   - Threat: Unwanted damage could happen
   - Threat Actor: Individual or object that can carry out a threat
   - Vulnerability: A flaw that can cause damage
   - **Threats * Vulnerabilities = Risk**
   - Due care: reasonable effort to protect (do correct). Due diligence: Ongoing effort to remain protected (due maintain)
   - Risk Policy: Contains overall risk management objectives or policies

4. Risk Management
   - Mitigating risks to an acceptable level - important function of security governance and management.

- **Risk Identification**
  - Asset Valuation
    - Critical Component of Risk Identification (Inventory of Assets)
    - Identify the value of the assets by contacting business owners/Senior Management. 100% Security is not possible in all assets.
  - Threat Analysis
    - Next step is identify the possible threats , possible consequence to the organization ,determine the probable frequency of threat events.
  - Vulnerability Assessment
    - A vulnerability assessment provides the baseline for determining appropriate and necessary safeguards.
- **Risk Analysis**

  Risk analysis is all about analyze the result of a risk assessment in order to make the risk management the decision. Provide outputs from Risk Identification, Threat Analysis and Vulnerability assessment to Risk Analysis phase.
  - Risk Analysis involves four steps
    - Identify the assets to be protected including sensitivity
    - Define Specific Threats
    - Calculate Annualized Loss Expectancy (ALE) in case of Quantitative
    - Select appropriate safeguards.
  - Qualitative Risk Analysis - FAST (High , low , medium)

    Qualitative risk analysis is **subjective, as it's carried out by individuals participating** in a project based on their personal perceptions of the risk likelihood and consequences. The purpose of such analysis is to increase the awareness of the most likely and severe risks, identify weak spots of a project, and create risk responses to reduce the effect that these risks will have on a project.
    - Produce descriptive versus measurable results
      - **Typically Conducted when**
        - The Risk assessors have limited expertise in Qualitative Risk Assessment
        - Time frame to complete Risk Assessment is short
        - The organization doesn't have significant amount of data readily available
        - The available assessors and team are long-term employees and have significant experience with business and critical systems. - driven by experience & judgement.
      - **Qualitative Risk Assessment Process:**
        - Approval - > form Risk assessment Team -> analyze data -> calculate risk -> countermeasure recommendations
  - Quantitative Risk Analysis - Effective (Numbers , Dollars)
    - Quantitative risk analysis is objective and requires a list of prioritized potential project risks, usually created during the qualitative risk analysis. To save time, quantitative risk analysis is usually carried out only for the **highest probability and impact risks**. The main purpose of this analysis is to analytically identify the most effective risk response strategies that will minimize the risk influence on project objectives.
    - Quantitative risk assessments assign numeric and **monetary values** to all elements of the assessment.
    - The ALE (annualized loss expectancy) formula is used for quantitative risk analysis
    - Quantitative risk assessment elements include:
      - Asset Value (AV) -$
      - Exposure Factor (EF) - %
      - Single loss Expectancy (SLE) - $ (SLE = EF * AV)
      - Annualized rate of occurrence (ARO) -# (Default Value is 1 is no ARO)
      - Annualized loss Expectancy (ALE) -$ (ALE=SLE*ARO)
      - Annual Cost Safeguard (ACS)

        = ACS = ALE before safeguards - ALE after safeguard - cost of the safe guard
- Risk Treatment
  - Risk Treatment is the process of selecting and implementing of measures to modify risk.
  - Risk treatment measures can include avoiding, optimizing, transferring or retaining risk.
  - Once risks have been identified and assessed, all techniques to manage the risk fall into one or more of these

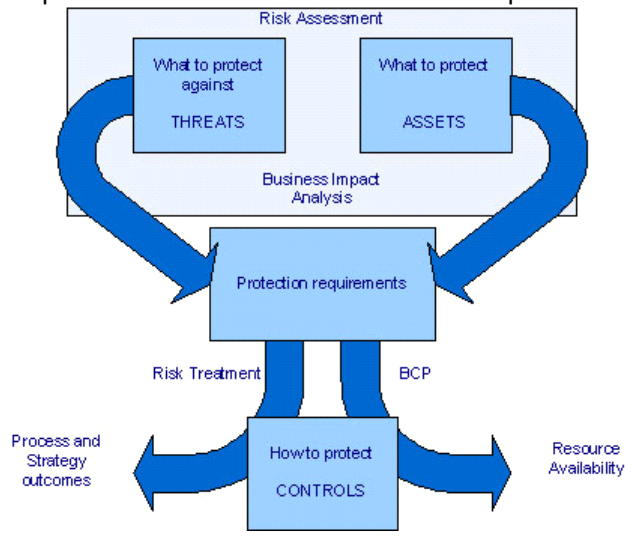
four major categories

- ◇ Risk Avoidance (eliminate, withdraw from or not become involved)
- ◇ Risk Reduction (optimize – mitigate)
- ◇ Risk Transfer (transfer – outsource or insure)
- ◇ Risk Retention (accept and budget)

- **Risk appetite:** The level of risk the organization is willing to **accept**. Organization decides on the risk appetite.
- **Risk Avoidance:** The practice of coming up with **alternatives** so that risk in question is not realized, stop the source of the risk. Not doing something risky.
  For example, have you ever heard a friend, or parents of a friend, complain about the costs of insuring an underage driver? How about the risks that many of these children face as they become mobile? Some of these families will decide that the child in question will not be allowed to drive the family car, but will rather wait until he or she is of legal age (that is, 18 years of age) before committing to owning, insuring, and driving a motor vehicle.

- **Risk Transference:** The practice of **passing** on the risk in question to another entity, still accountable. SLE is best control for risk transfer.
- **Risk Acceptance:** The practice of **accepting certain risks** based on business decision that weighs the cost vs benefit of a risk. Ex: Business opportunity is higher than risk, risk value is less than risk appetite, Cost of controls is greater than risk.
  The decision to accept risk should not be taken lightly, nor without appropriate information to justify the decision. The cost versus benefit, the organization's willingness to monitor the risk long term, and the impact it has on the outside world's view of the organization must all be taken into account when deciding to accept risk.
  It is important to note that there are organizations who may also track containment of risk. Containment lessens the impact to an organization if or when an exposure is exploited through distribution of critical asset (that is, people, processes, data, technologies, and facilities).

- **Risk Mitigation:** The decrease in the level of risk presented through
  - ◇ **implementation of controls**. - mitigating risk to an acceptable level. Risk remaining after implementation the controls is called **Residual risk**.
  - ◇ For example, to lessen the risk of exposing personal and financial information that is highly sensitive and confidential, organizations put countermeasures in place, such as firewalls, intrusion detection/prevention systems, and other mechanisms, to deter malicious outsiders from accessing this highly sensitive information. In the underage driver example, risk mitigation could take the form of driver education for the child
  - ◇ Representation of Risk Residual is an Acceptance risk



- **Return on Security Investment (ROI)**
  - Organization must ensure that remediation activities are implemented after risk assessment followed by continuous monitoring. Organization also

assigns people who takes accountability.

- Frameworks for Risk Assessment Process :- RMF (NIST)
- RMF - Continuous monitoring of risk controls is important.
- Annual Cost Safeguard (ACS)
  - ACS = ALE before safeguards - ALE after safeguard - cost of the safe guard
  - ◇ The risk assessment team must evaluate the security controls' functionality and effectiveness
    For example, if the ALE of the threat of a hacker bringing down a web server is $12,000 prior to implementing the suggested safeguard, and the ALE is $3,000 after implementing the safeguard, while the annual cost of maintenance and operation of the safeguard is $650 then the value of this safeguard to the company is $8,350 each year.

- **EXAM NOTES:- sequence for the exam -**
  - **Categorize (Information System)**
  - **Select (Security Controls)**
  - **Implement (Security Controls)**
  - **Assess (Security Controls)**
  - **Authorize (Information System)**
  - **Monitor (Security Controls)**

- **Countermeasure Selection**
  - When selecting the countermeasures there are factors must be considered.
    - ◇ Accountability: who is accountable
    - ◇ Auditability:
    - ◇ Whether source is trusted
    - ◇ Cost effectiveness
    - ◇ Security - How secure it is
    - ◇ Protections for CIA of assets
    - ◇ If it creates additional issues during operation. (Identity RCA, reassess the solution, notify owners, 24-72 Hours until it creates high risk to the organization)
    - ◇ If it leaves residual data from its function.

- **Key to Successful implementation: - Exam Question**
  - Document and effectively communicate all of the efforts being done by platform and area to management.
  - Produce a real inventory of the controls that you are going to use the against the risks.
  - Secure carefully and strong access control needs to be defined on these documents.

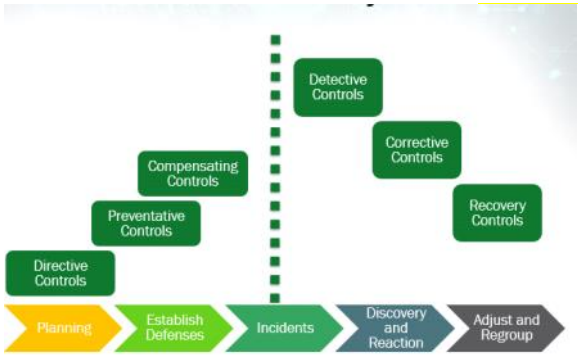
❖ Controls, Countermeasure and Safeguards

Type of Controls

- **Administrative (Security Awareness Training)**
  - □ Controls relating to oversight laws ,rules & regulation. e.g. Policies, procedures, training, audits, compliance reporting.
  - □ Controls is administrative in nature, which represent policies of management.
- **Physical**
  - □ Control that can have material structure e.g. Gate ,Guard ,Alarms ,door , CCTV.
  - □ Control to protect the assets in an organization. Covers a broad spectrum of controls to protect the organization resources.
- **Logical/Technical (Firewall)**
  - □ Mechanisms implemented in Digital and electronic infrastructure of an organization enforces organization security strategy.
  - □ Ex: Network access, remote access, system access, application access, malware control and cryptography.

2. Type of Categories (DPD CDR C)

- **Directive** - designed to specify acceptable rule of behavior in organization ex: Policy, social media restricted 9-5PM.
- **Preventive** Intended to avoid an incident from occurring.
- **Detective** Helps identify an incident's activities and potentially an intrude
- **Corrective** Fixes components or systems after an incident has occurred
- **Deterrent** Intended to discourage a potential attacker.
- **Recovery** Intended to bring the environment back to regular operations
- **Compensating** Controls that provide an alternative measure of control



3. Security/Control Assessment
   - The assessment results provide organizational officials
     - **Evidence about effectiveness of the security controls.**
     - Indication of quality of risk management processes.
     - Information about strengths/weaknesses of systems which supports org mission and business function in global environment
   - **Security Control Assessment is the principle which ensures that the security policies are enforced in an organization and are meeting their goals and objectives.**
     - Security Control Assessment result provides the surety or evidence enforcement of security control in an organization as well as its effectiveness over the organization's system. CSA also reports about the quality of risk management processes including the incident response action plans.

   - **Effectiveness Assessment Methods.**
     - Key to successful testing and valuable pen test is clearly defined objectives, scope, stated goals and agreed upon limitations.
     - An organization should employ various methods to determine the access control effectiveness.
       - **Vulnerability Assessment**
         - Provides GAP and understands the vulnerabilities in the system.
         - Reviews the organization's IT environment for known vulnerabilities
         - Vulnerability scanning, Finalize analysis and Communicate results and present to management. Report Findings to mgmt. Action should be based on the criticality.
       - **Penetration Testing**
         - Simulate an attack on a system or network to evaluate the risk provide of an environment.
         - The key to successful and valuable penetration testing is clearly defined objectives, scope , stated goals, agreed-upon limitation and acceptable activities.
         - The key to successful and valuable penetration testing is clearly defined objectives, scope, stated goals, agreed-upon limitations, and acceptable activities
         - **NOTE:- Take approval from management and perform Pen Test. - exploit CIA**
           - Strategies
             - Internal Testing
               - Performed within the organizational internal network
             - External Testing
               - Attacks to organization network perimeter ,target DNS ,EMAIL ,FW ,WEB SERVER.
             - Blind Testing
               - Red Team will not get any information, they need to gather all the information and perform this attack, company will observe the skills, how effective they are, how the organization is ready. **Blue team is aware about PT.**
             - Double-Blind Testing
               - In Double blind, **Blue team is not aware about any PT**, how effective the controls and incidents are is measured in Double blind testing.
           - **Base on Knowledge**
             - Zero Knowledge Testing

- Black Box -No information about the target.
- Partial Knowledge Testing
  - Gray Box -Partial Knowledge
- Full Knowledge Testing
  - White Box -Full Knowledge

- **Document Findings**
  - Specific areas covered in documentation areas ,Vulnerabilities discovered in target system, gaps in network measure.
  - intrusion detection and response capability, observe of log activities and suggested countermeasures
- **Different Methods**
  - DOS Testing - availability point of view
  - War Dialing - penetrate the modems/telephones
  - War Driving - Check for Open WIFI
  - Social Engineering - that relies heavily on human interaction and often involves manipulating people into breaking normal security procedures .
  - Pivoting Method: Penetration of one network to other network is called pivoting.
  - Traffic Padding: is not a technique used to perform penetration test.

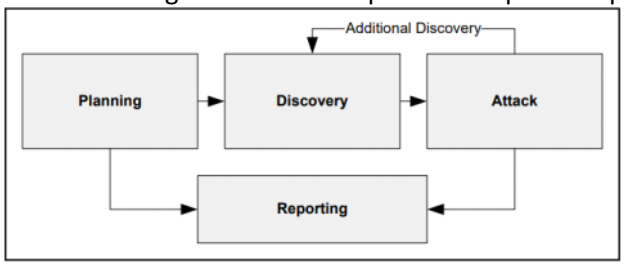


Figure 5-1. Four-Stage Penetration Testing Methodology

❖ Threat Modeling Concepts and Methodologies

- Scenario analysis of the threat and possible outcome is called Threat modeling
- Threat modeling is called as a scenario analysis of a threat,
- 90% Threat Modeling is conducted during the design of application, during the design we define the architecture.
- Threat is an action that comprise the security.

1. **Threat Modeling Concept**
   - Threat
     - Term used to denote a potential cause of an unwanted incident, which may result in harm to a system or organization is
   - Threat Actor - Adversaries with malicious intent
   - Vulnerability - Weakness in system
   - Exploit - Successfully taking advantage of a vulnerability
   - Targeted Attack - Threat actor chooses a target for a specific objective
   - Opportunistic Attack - Threat actor takes advantage of a vulnerable target (not previously known to them)
   - Incident - Event that potentially compromises the CIA of information or information system.

2. **Threat Modeling**
   - Approach to identifying and categorizing potential threats.
   - Ultimate goal of threat Modelling is to identify the outcome of the possible threat.
     - Scope - Network, System, Application or Data
     - Identify Threat agents and possible threats
     - Understand Current Controls
     - Identify exploitable vulnerabilities
     - Priorities identified risk
     - Identify controls to reduce risk to acceptable levels
   - **Threat Modeling Process**

- **Define security requirements**
- **Creating an application diagram**
- **Identify threats**
- **Mitigating threats**

3**STRIDE (EXAM NOTE IMP)**

- Created by Microsoft, is actually a threat classification system used to inform software developers during the development process.
  - **S - SPOOFING -** the type of threat wherein an attacker poses an entity other than the attacker.
  - **T - TEMPER -** when the attacker attempts to modify the target data in an unauthorized way.
  - **R - REPUDIATION -** when the attacker, as a participant of a transaction, can deny the attacker's participation in that transaction.
  - **I - INFORMATION DISCLOUSER -** where an authorized user discloses protected data accidentally to unauthorized users
  - **D - DOS -** an attack on the availability system.
  - **E - ELEVATION OF PRIVILAGE -** when an attacker not only gains access to the target but can attain a level of control with which to completely disable/destroy the entire target

- **PASTA (PROCESS FOR ATTACK SIMULATION & THREAT ANALYSIS)**
  - It provides a seven-step process for aligning business objectives and technical requirements, taking into account compliance issues and business analysis
  - Stages
    - Stage 1 - Definition of Objectives for the Analysis of Risks
    - Stage 2 - Definition of Technical Scope
    - Stage 3 - Application of Decomposition and Analysis
    - Stage 4 - Threat Analysis
    - Stage 5 - Weakness and Vulnerability Analysis
    - Stage 6 - Attack Modelling and Simulation
    - Stage 7 - Risk Analysis and Management

❖ **For questions and more clarity refer Threat Modeling Link**

□ **Physical Infrastructure**

- Disruption or destruction of physical structures and facilities
  - Tailgating Attacks
    - An attacker, seeking entry to a restricted area secured by unattended electronic access control simply walks in behind a person who has legitimate access, following common courtesy, the legitimate person will usually hold the door open for the attacker. Tailgating is mostly physical point of view.
  - Piggybacking
    - With Consent someone just follows the person through door.

□ **Human**

- Disruption, manipulation, or compromise of people
  - Social Engineering Attack
    - Attacker use human interaction to obtain or compromise information about user/organization/computer
  - Phishing Attacks
    - A form of social engineering, use email or malicious web sites to solicit personal information by posing as a trustworthy organization / person.
  - Pretexting Attacks
    - The act of creating and using an invented scenario (the pre text) to engage a targeted victim in a manner that increases the chance the victim will divulge information or perform actions that would be unlikely in ordinary circumstances
  - Baiting Attacks

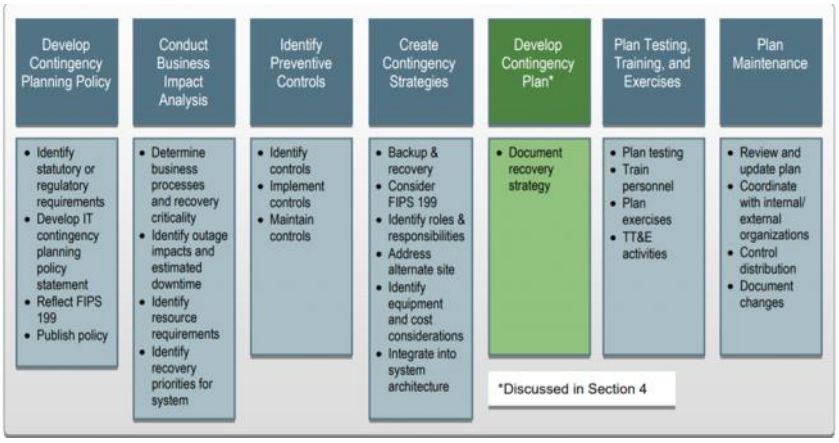
- The attacker leaves a malware infected CD-ROM or USB flash drive in a location sure to be found, gives it a legitimate looking and curiosity-piquing label, and simply waits for the victim to use the device

❖ **Apply Risk Management Concepts to the Supply Chain**

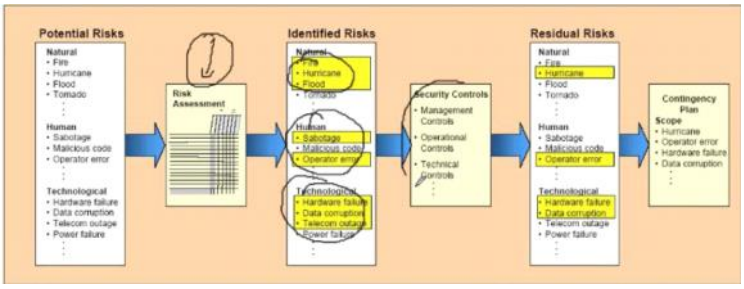
- **Supply Chain Management**
  - Managing the individuals, organizations, resources, activities and technologies for the manufacture and sale of product or service.
  - Factors to consider
    - □ Applies to Physical and digital goods and services
    - □ Use Trusted vendors and suppliers
    - □ Ensure supplies are authentic and do not contain malicious intent
    - □ Test and verify acquired products and good against set security standards.
- **Acquisition Strategy**
  - Conduct Risk management during acquisition
  - A Policy, process or produce to reduce security risks and related incidents for acquired products,
  - Address anything that could introduce risk to the system,
  - Applies to ALL externally acquired products and services,
  - Should include supply chain management or create a separate supply chain policy

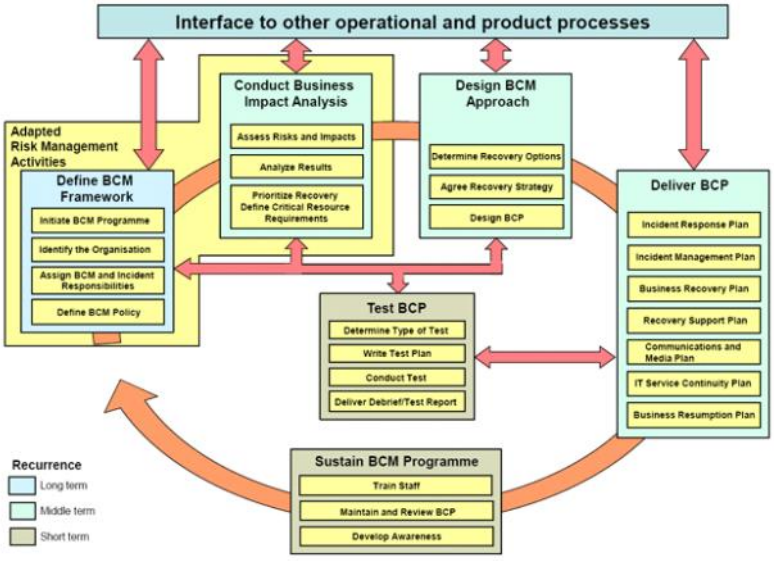
- **Regular Third Party Assessment**
  - When we hire contractor, there are practices that needs to be followed.
  - The below are to be reviewed during Third party assessments
    - □ On-site assessments
    - □ Document exchange and Review
    - □ Process/Policy Review
    - □ Whenever we take a service, we sign Service Level Agreement (SLA) signed between Customer and Provider.
  - **Service Level Requirement (SLA)**
    - □ SLAs define the agreed upon the level of performance and compensation or penalty between the provider and the customer.
    - □ Assurance can only gained through inspection ,review and assessment, SLA are defined from SLR (Service Level Requirements) -required shared by the customer to vendor, SLA signed between customer and vendor.
    - □ **Most important element to include in SLA is Services metrics and Right to Audit - customer can ask audit report SOC, ISO Reports..Etc.,**
    - □ **Review Annually**
    - □ Single SLA covers multiple services.
  - **Service Level Requirement (SLR)**
    - □ contains the requirement for a service from the client view point - detailed service level targets, mutual responsibilities, other requirements specific to a certain group of customers. Draft of SLA.
  - **Service Level Report (SLRep**)
    - □ Shared from Vendor to customer.
    - □ Includes comparison agreed vs. achieves service levels (primary concern) talks about Information service usage, Provides ongoing measures for measurement, Exceptional events.
  - **Operational Level Agreement (OLA)**
    - □ Agreement describes the responsibilities of each internal support group toward other support groups, including the process and timeframe for delivery of their services.
    - □ Review Internally , Weekly meeting.

❖ Business Continuity (BC) Requirements


Develop Contingency Planning Policy
• Identify statutory or regulatory requirements
• Develop IT contingency planning policy statement
• Reflect FIPS 199
• Publish policy
Conduct Business Impact Analysis
• Determine business processes and recovery criticality
• Identify outage impacts and estimated downtime
• Identify resource requirements
• Identify recovery priorities for system
Identify Preventive Controls
• Identify controls
• Implement controls
• Maintain controls
Create Contingency Strategies
• Backup & recovery
• Consider FIPS 199
• Identify roles & responsibilities
• Address alternate site
• Identify equipment and cost considerations
• Integrate into system architecture
Develop Contingency Plan*
• Document recovery strategy
*Discussed in Section 4
Plan Testing, Training, and Exercises
• Plan testing
• Train personnel
• Plan exercises
• TT&E activities
Plan Maintenance
• Review and update plan
• Coordinate with internal/ external organizations
• Control distribution
• Document changes

❖


Potential Risks
Natural
• Fire
• Hurricane
• Flood
• Tornado
Human
• Sabotage
• Malicious code
• Operator error
Technological
• Hardware failure
• Data corruption
• Telecom outage
• Power failure
Risk Assessment
Identified Risks
Security Controls
• Management Controls
• Operational Controls
• Technical Controls
Residual Risks
Contingency Plan
Scope
• Hurricane
• Operator error
• Hardware failure
• Data corruption


Interface to other operational and product processes
Adapted Risk Management Activities
Define BCM Framework
Initiate BCM Programme
Identify the Organisation
Assign BCM and Incident Responsibilities
Define BCM Policy
Conduct Business Impact Analysis
Assess Risks and Impacts
Analyze Results
Prioritize Recovery Define Critical Resource Requirements
Design BCM Approach
Determine Recovery Options
Agree Recovery Strategy
Design BCP
Deliver BCP
Incident Response Plan
Incident Management Plan
Business Recovery Plan
Recovery Support Plan
Communications and Media Plan
IT Service Continuity Plan
Business Resumption Plan
Test BCP
Determine Type of Test
Write Test Plan
Conduct Test
Deliver Debrief/Test Report
Sustain BCM Programme
Train Staff
Maintain and Review BCP
Develop Awareness
Recurrence
Long term
Middle term
Short term

BIA Steps

The more detailed and granular steps of a BIA are outlined here:

1. Select individuals to interview for data gathering.
2. Create data-gathering techniques (surveys, questionnaires, qualitative and quantitative approaches).
3. Identify the company's critical business functions.
4. Identify the resources these functions depend upon.
5. Calculate how long these functions can survive without these resources.
6. Identify vulnerabilities and threats to these functions.
7. Calculate the risk for each different business function.
8. Document findings and report them to management.

○ Business Continuity Plan Introduction

- Business Continuity is the capability of a business to operate in adverse conditions.
- The documentation of a predetermined set of instructions or procedures that describe how an organization's mission/business processes will be sustained during and after a significant disruption
- The objective of business continuity planning is to prepare for the continued operation of essential functions and services during disruption of normal operating conditions.
- The documentation of predetermined set of instructions or procedures that describe how an organization's mission/business processes will be sustained during and after a significant disruption
- **BCP implementation is accountability of Senior Management**
- **BCP is a strategic Plan**

○ Disaster Recovery Plan

- A Written plan for recovering one or more information systems at an alternate facility in response to a major hardware or software failure or destruction of facilities
- **Tactical/Operational Plan for only IT. DR is subset of BCP**

○ Phases of BCP (CBK)

1. Project Scope and Planning

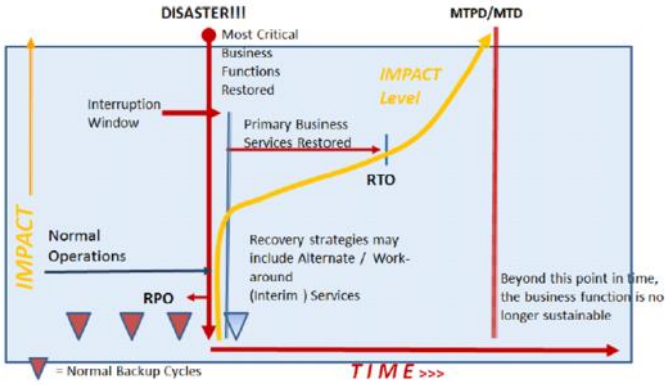
- □ First step in building the BC Program is Project Initiation and Management
- □ Obtain senior management support to forward the project
- □ Define a project scope, objectives to be achieved and planning assumptions - responsibility of the project manager.
- □ Estimate project resources needs to be successful both human and financial resources
- □ Define timeline and major project deliverables.
- □ The BCP committee should be as large as it needs to be in order to represent each department within the organization.
- □ **There are two points to be considered -**
  - **the risk they are accepting by not having one.**
  - **second potential cost to the organization if disaster strikes.**

2. Business Impact Assessment (BIA)

- □ The objective of a Business Impact Analysis (BIA) is a BCP Phase to identify essential services, systems, and infrastructure.
- □ Essential means that the absence of or disruption of services would result in significant, irrecoverable, or irreparable harm to the organization, employees, business partners, constituents, community, or country.
- □ Outcome of BIA is a prioritized matrix of services, systems ,and infrastructure
- □ **The first step in a business impact analysis (BIA) is creating data-gathering techniques.**
- □ Business Impact Analysis (BIA) is used by management to
  - Make investment decisions
  - Prioritize resources.
  - Guide the development of incident response, disaster recovery, and business contingency (continuity) plans.
- □ **BIA Includes**
  - A vulnerability assessment and risk analysis.
  - A prioritization of critical processes.
  - Estimates of tolerable downtime.
  - The impact of financial loss.
  - The possibility of reduced efficiency in operations
  - Resources needed to restore normal business operations
- □ **The BIA process should answer the following questions.**
  - What is the organization's essential business process?
  - What is the impact of a disruption (e.g. life, property, safety, finance, reputation)?

- What are the related resources and dependencies (including single point of failure)?
- What are the process, system, and data recovery requirements?

□ Business Impact Metrics
- Classify all functions and applications as to their time sensitivity for recovery
  - ◇ Work Recovery Time (WRT)
    - Time it take to verify the restoration
  - ◇ Maximum Tolerable Downtime (MTD) & Maximum Tolerable Outage (MTO)
    - Maximum time a process/service can be unavailable without causing significant harm to the business.
    - **MTD = RTO + WRT (or) RTO + WRT < MTD**
    - The MTD represents the total amount of time the system owner/authorizing official is willing to accept for a mission/business process outage or disruption and includes all impact considerations.
  - ◇ Recovery Time Objective (RTO)
    - Amount of time allocated for system recovery - Must be less than the maximum amount of time a system resource can be unavailable before there is an unacceptable impact on other system resources or business process.
    - RTO defines the maximum amount of time that a system resource can remain unavailable before there is an unacceptable impact on other system resources, supported mission/business processes, and the MTD
      (RTO < MTD)
  - ◇ Recovery Point Objective (RPO)
    - Acceptable data loss - The point in time, prior to a disruption or system outage that data can be Recovered



3. Continuity planning/Contingency Strategies

- Step 1: Document all costs associated with each contingencies.
- Step 2: Obtain cost estimates for any outside services (using RFI, RFQ, or RFP).
- Step 3: Develop written agreements for outside services (i.e. Service Level Agreement (SLA)).
- Step 4: Evaluate resumption strategies based on a full loss of the facility.
- Step 5: Identify risk reduction measures and update Business Resumption Plan (BRP).
- Step 6: Document recovery strategies and present to management for comments and approval.

4. Approval and Implementation

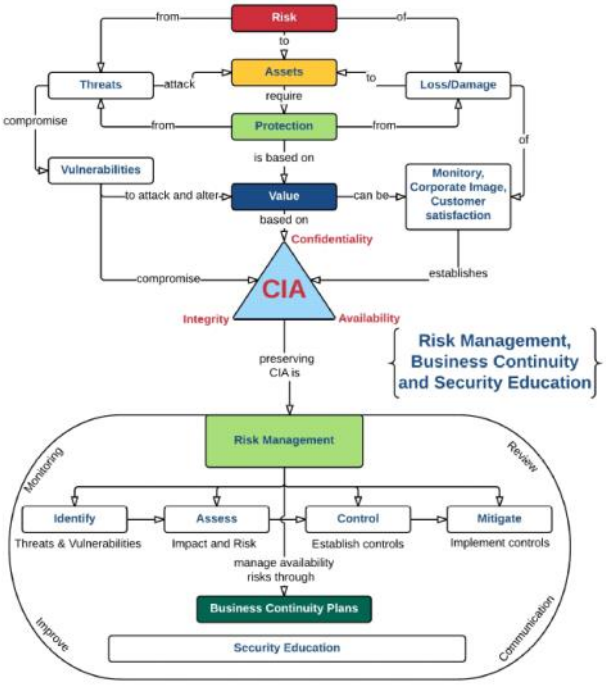
□ Plan Approval
- CEO should endorse plan else senior officer
- Indicates dedication of the business to the process of BCP

□ Plan Implementation
- Create Implementation Guide/Schedule.
- Deploy Resources
- Supervise Maintenance Plan

□ Train & Educate Employees

- Distribute plan on need to know basis
- Everyone should get at least an overview

- **BCP Relation to Risk Management**
  - Potential Risks (Natural/Human/Technological) → Risk Assessment → Identified risks → Security Controls → Residual Risks → Contingency plan
  - Risk Management is all about mitigating risks to an acceptable level, Understand the differences between Potential, Identified and Residual risks.



❖ **Personnel Security Policies and Procedures**

- Employee Life Cycle
  - **Hiring Process**
    - **During employment screening the below practices must be covered**
      - Job description
      - Reference checks (also called personal reference check)
      - Education, Licensing, Certification and Verification
      - Background checks. Play very important role whenever we hire any resource
    - **Background investigation**: is basically one of the important part, background check can uncover the gaps in employment misrepresentation of job title, reason of leaving the job, validating of certifications and criminal history.
  - **On-Boarding Process**
    - Agreement varies from organization to organization.
    - The agreement includes Code of Conduct, Conflict of interest, Gift-handling, Ethics statements, Non-disclosure, Non-compete, Acceptable use.
    - NDA is always aligned with the profile/bind with legal . when you leave the organization, NDA is still applicable, Acceptable Use policy is limited to the organization. If you were involved any wrongdoing, company has right to terminate.
    - Steps process = Must review
      • The new employee attends all required security awareness training.
      • The new employee must read all security policies, be given an opportunity to have any questions about the policies answered, and sign a statement indicating they understand and will comply with the policies.
      • The new employee is issued all appropriate identification badges, keys, and access tokens pursuant to their assigned roles.

- Off-Boarding
  - **Voluntary (friendly)**
    - The primary concern for ISM is return assets back and disable the access.
    - Notice period - 30d/60d based on the organization.
    - Followed by Exit interview. User manager (employee manager) will notify the security department of the termination.
  - **Involuntary (unfriendly)**
    - Involuntarily means you did not solicit or request the action or result
    - Terminated would mean that something has been abruptly halted. In the world of employer employee relationships it would tend to imply that someone got fired. They did not quit and voluntarily terminate but the employer asked them to leave.

- Employment
  - User Security Controls
    - Policy/Agreements
      - Confidentiality Agreement, Acceptable Use Policy and Agreement (AUP)
    - Training
      - Ongoing education, training, and awareness programs
    - Job Rotation
      - Rotating assignments - Job rotation is compensatory control,
      - Job rotation is like a preventative action that we can take to prevent fraud in addition to Separation of Duties.
      - Business unit head is responsible for job rotations, ISM is only enforcing these controls
      - Also, it reduces the risk of Collusion
      - Job Rotation prevent Fraud and Mandatory Vacation detect fraud
    - Separation of Duties / Segregation of Duties
      - Breaking a task into processes so that no one subject is in complete control
      - But promote collusion
    - Mandatory Vacation
      - Requiring employees to take a set amount of vacation time.
      - Primary objective of Mandatory vacation is to detect a fraud not to prevent a fraud.
    - Dual Control
      - Requiring more than one subject or key to complete a specific task
    - Need to know
      - What I can do with this information
      - **Proper clearance must be in place as well**
    - Least Privilege
      - give user & process only required privilege removes ability to abuse of the system
      - Grant users *only the rights and permissions* they need to perform their job and no more
    - Clean Desk
      - Requirement to never leave confidential data (paper, monitor, whiteboard) unattended or within view of unauthorized personnel
  - Personnel Agreement
    - **Confidentiality /Non-disclosure (NDA)**
      - Protect data from unauthorized disclosure
      - Establish data ownership
      - Protect information from disclosure
      - Prevent forfeiture of patent rights
      - Define handling standards including disposal
    - **Acceptable Use Policy (AUP) Agreement**
      - Set forth proper use of information systems, handling standards, monitoring, and privacy expectations
      - An AUP should be written in language that can be easily and unequivocally understood.
      - By signing the associated agreement, the user acknowledges, understands, and agrees to the stated rules and obligations

❖ **Awareness vs Training vs Education**

- The goal of creating awareness is to bring security to the forefront and make it a recognized entity for users
- Awareness establishes a minimum standard common denominator or foundation of security understanding
- All personnel should be fully aware of their security responsibilities and liabilities. They should be trained to know what to do and what not to do.
- The awareness program should also be tied to an understanding of how the corporate culture will affect and impact security for individuals as well as the organization as a whole.
- Security awareness and training can often be improved through gamification
- Methods and techniques to present awareness and training should be revised and improved over time to maximize benefits
- Gamification is a means to encourage compliance and engagement by integrating common elements of game play into other activities, such as security compliance and behavior change.
- All new employees require some level of training so they will be able to comply with all standards, guidelines, and procedures mandated by the security policy
- Training and awareness program effectiveness evaluation should take place on an ongoing or continuous basis.
- A well-designed, engaging, and successful security training program should result in a measurable reduction in employee-related security incident management costs, hopefully far exceeding the cost of the training program itself

❖ For last moment Review Domain 1 Security and Risk Management (Part1) Link

❖ For last moment Review Domain 1 Security and Risk Management (Part 2) Link

❖ For last moment Review Domain 1 Security and Risk Management (Part 3) Link